

Introduction du sujet

Vous devez auditer la conformité RGPD de l'entreprise fictive **X-corp** . Ils auront pour mission d'analyser les pratiques de X-corp en matière de protection des données, de réaliser un registre des traitements, d'effectuer une analyse d'impact (DPIA), de simuler la gestion d'une violation de données, et de réaliser un audit de conformité complet.

PS : La description de X-corp se trouve en fin de document.

Jour 1

Découverte et analyse de l'organisation et des traitements de données.
Rédigez un rapport synthétique (3-4 pages) présentant les concepts clés du RGPD, incluant des exemples concrets.

Jour 2

Compléter le registre des traitements pour X-Corp.

Jour 3

Réaliser une DPIA pour un projet de X-Corp.

Jour 4

Simuler la gestion d'une violation de données chez X-Corp.

Jour 5

Réaliser un audit de conformité RGPD pour X-Corp.

Compétences visées

- Appliquer les bonnes pratiques dans l'administration des infrastructures
- Participer à l'élaboration et à la mise en œuvre de la politique de sécurité
- Participer à la détection et au traitement des incidents de sécurité

Rendu

L'évaluation se fera sous forme de présentation en soutenance avec support à l'équipe pédagogique.

Base de connaissances

-
- [Outils de conformité au RGPD](#)
 - [Guide sur les bonnes pratiques RGPD](#)
 - [Guide pratique sur les droits des personnes](#)
 - [L'analyse d'impact relative à la protection des données](#)
 - [un logiciel pour réaliser son analyse d'impact sur la protection des données](#)

Entreprise Fictive : X-corp

- **Nom de l'entreprise :** X-corp
- **Secteur d'activité :** Technologie et services numériques
- **Siège social :** Paris, France
- **Effectif :** 150 employés
- **Site web :** www.X-corp.eu
- **Année de création :** 2012

Activités Principales :

X-corp est une entreprise spécialisée dans le développement de solutions logicielles pour la gestion des données et le marketing digital. Elle propose à ses clients (PME et grandes entreprises) des outils de gestion de bases de données clients, d'analyse de données, et de campagnes marketing automatisées.

Produits et Services :

1. DataManage :

- Logiciel de gestion de bases de données clients.
- Collecte, organise, et stocke les données clients, y compris les noms, adresses email, numéros de téléphone, et historique d'achats.
- Analyse comportementale des clients pour personnaliser les offres commerciales.

2. MarketInsight :

- Outil d'analyse de données pour le marketing digital.
- Segmentation de l'audience, suivi des performances des campagnes, et recommandations personnalisées.
- Utilisation de techniques d'IA pour prédire les tendances du marché.

3. AutoMail :

- Plateforme d'automatisation des campagnes emailing.
- Permet de créer des campagnes ciblées basées sur les comportements des utilisateurs.
- Intégration avec DataManage pour une personnalisation avancée.

Clients et Partenaires :

• Clients principaux :

- **RetailCo** : Chaîne de magasins de détail (800 000 clients).
- **HealthMed** : Société de services de santé (500 000 patients).
- **EduLearn** : Plateforme d'e-learning (300 000 utilisateurs).

• Partenaires technologiques :

- **CloudSecure** : Fournisseur de solutions de stockage sécurisé en cloud.

- **AdBoost** : Spécialiste de la publicité digitale ciblée.

Traitements de Données Sensibles :

1. Gestion des Clients pour RetailCo :

- **Données collectées** : Noms, adresses, emails, numéros de téléphone, historique d'achats, préférences de produits.
- **Finalité** : Personnalisation des offres et des promotions, amélioration de l'expérience client.
- **Base légale** : Consentement des clients.
- **Conservation** : 5 ans après le dernier contact.

2. Suivi des Patients pour HealthMed :

- **Données collectées** : Noms, adresses, emails, numéros de téléphone, historique médical, prescriptions.
- **Finalité** : Suivi des traitements, rappel des rendez-vous, personnalisation des conseils de santé.
- **Base légale** : Consentement explicite des patients.
- **Conservation** : 10 ans après la fin du traitement médical.
-

3. Analyse de l'Usage pour EduLearn :

- **Données collectées** : Identifiants utilisateurs, adresses email, parcours d'apprentissage, résultats d'examen.
- **Finalité** : Amélioration des parcours d'apprentissage, recommandations de cours, suivi des progrès.
- **Base légale** : consentement des utilisateurs.
- **Conservation** : 2 ans après la fin de l'utilisation de la plateforme.

Mesures de Sécurité en Place :

- **Pseudonymisation des données sensibles** : Pour limiter l'identification des individus en cas de fuite de données.
- **Chiffrement des données** : À la fois en transit et au repos, utilisant des standards AES-256.
- **Authentification à deux facteurs** : Pour l'accès aux systèmes internes.
- **Contrôle d'accès basé sur les rôles (RBAC)** : Les employés n'ont accès qu'aux données nécessaires à leurs fonctions.

Conformité et DPIA :

- **Délégué à la Protection des Données (DPO)** : Un DPO a été nommé et est chargé de superviser la conformité au RGPD.
- **DPIA effectuées** : Une DPIA a été réalisée pour chaque nouveau produit avant son lancement sur le marché.
- **Politique de conservation des données** : Revue tous les 2 ans pour s'assurer de la conformité.

Problèmes Récurrents :

- **Demandes de droit d'accès des utilisateurs** : Fréquemment reçues, avec un volume de 50 à 100 demandes par mois.
- **Gestion des consentements** : Problèmes pour gérer et documenter les consentements pour le marketing, notamment pour les campagnes via AutoMail.

Violations de données : X-corp a subi une fuite de données mineure il y a un an, exposant 2 000 enregistrements clients. La gestion de cet incident a révélé des lacunes dans le processus de réponse.